

Unit 7: Digital Certificates

What we have seen until now...

- Key Establishment Protocols
 - Diffie-Hellman and DH on elliptic curves
 - They allow us to agree on a key without the need for a secure channel
- Asymmetric encryption
 - It allows messages to be sent to the recipient without having to pre-negotiate a key
 - We can also use it to agree on a symmetric encryption key with another entity
- Hash Functions
 - They allow us to verify the integrity of a message
- Digital signature
 - They make it possible to establish "non-repudiation"

Outline

1. Trust in Digital Environments
2. Public Key Infrastructure
3. Certification Authorities
4. Digital Certificates

Trust in Digital Environments





Peter Steiner, New Yorker

Trusted Third Parties

- Main problem in asymmetric encryption
 - We can encrypt with the receiver's public key
 - How do I know that this key is their actual key?
- Solution
 - Needs
 - A mechanism to verify whether public keys are real
 - A mechanism that allows me to bind public keys to identities
 - Proposal, something...
 - ...trusted by sender and receiver
 - ... independent that verifies identities
 - ... which is responsible for validating public keys once they have been verified
 - ... who is responsible for keeping the information up to date

Public Key Infrastructure

Public Key Infrastructure

- Set of roles, policies, hardware, and software that enables
 - Creating
 - Managing
 - Distributing
 - Storing y
 - Revoking

Digital Certificates

- The source of trust in a public key infrastructure system starts at the Certification Authority (CA)

Certification Authorities

What is a Certification Authority?

- They are trusted entities in charge of certifying that a public key is valid and that it belongs to a certain person, website or machine
 - Authenticate the user's or system's public key
 - Only the CA can modify the user's certificate without it being detected
- For the system to work, it is essential that all users recognize and trust the certificate authority
- Examples of Certification Authorities:
 - Avast, DigiCert, Verisign, Entrust, GlobalSign, Google, SSL Corporation, Symantec, Thawte, Terena, ...
 - In Spain: FNMT Fábrica Nacional de Moneda y Timbre, CamerFirma. ...

CAs and Digital Certificates



1. User B requests a certificate.
2. The CA validates User B's identity and grants them a certificate.
3. B presents the certificate granted by AC with its identity to user A.
4. User A is suspicious because he doesn't know User B. He asks the CA and verifies the identity of User B with the certificate that has been presented to him.
5. The CA verifies that the certificate submitted by User B is valid.
6. The CA confirms to User A that User B's certificate is valid.

Obtaining a User Certificate

The user pre-registers with the Certificate Authority.

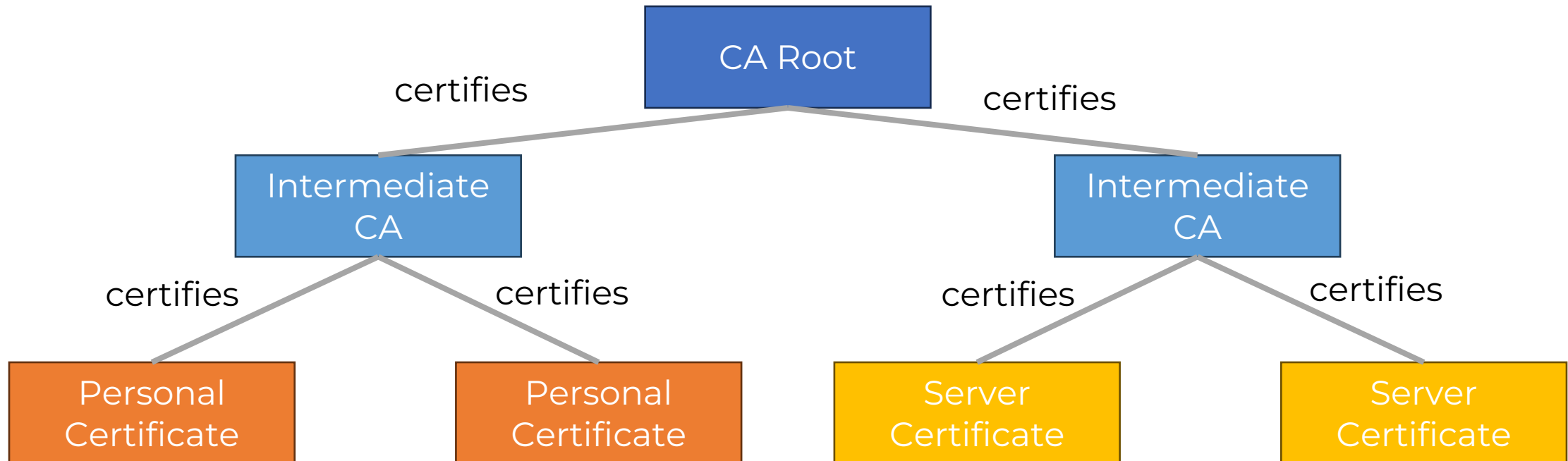


**Once issued, the Certificate Authority
supplies the certificate to the user**

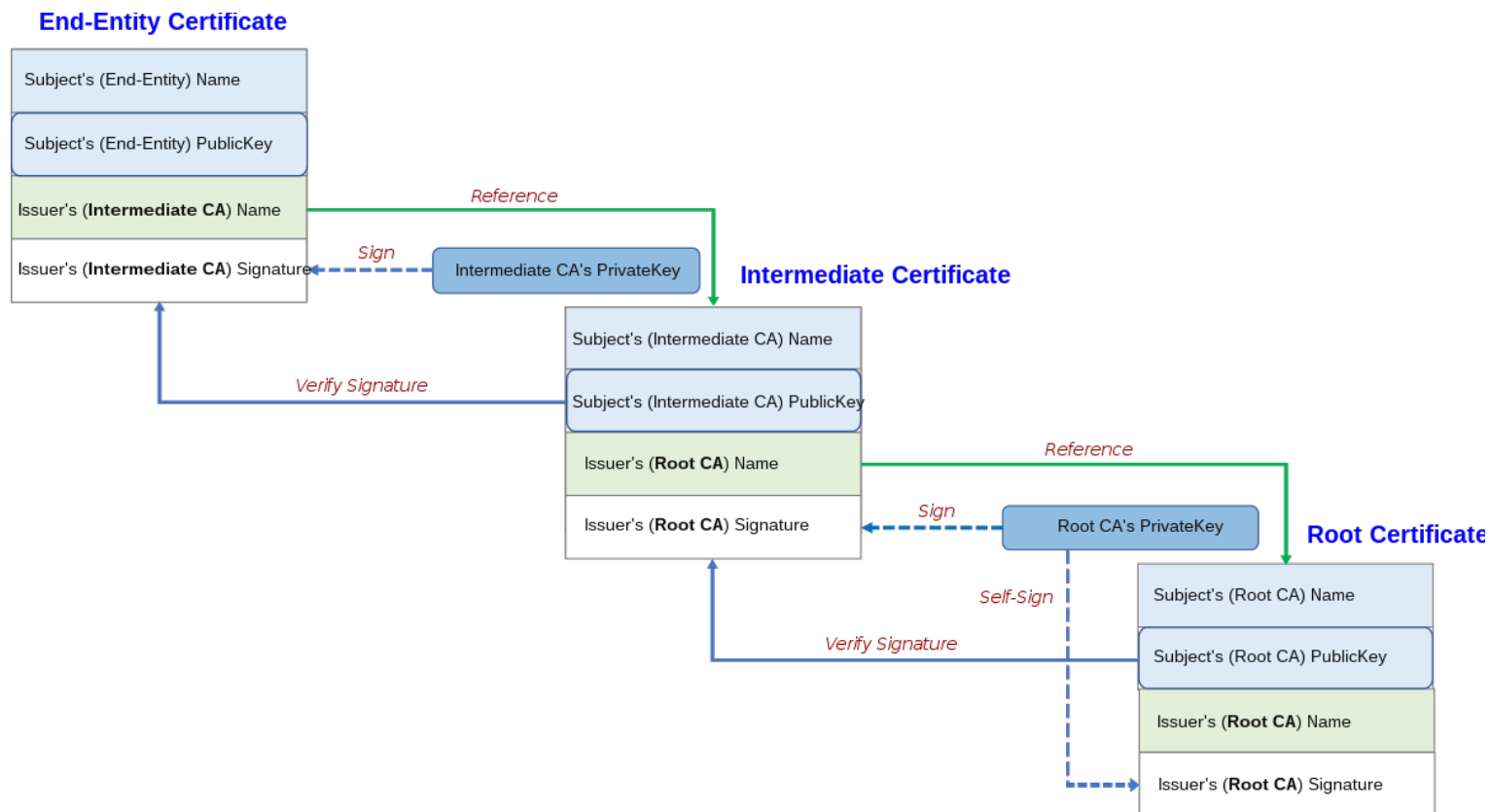
Remote Registration

Chain of Trust

How can we ensure that the certificate given to an entity is valid?



Example in TLS



Fuente: [Wikimedia](https://en.wikipedia.org/wiki/TLS_(protocol)#Certificate_chain)

Digital Certificates

X.509 Digital Certificate

It is a digital document by means of which a trusted third party – a certificate authority (CA) – electronically certifies the authenticity of the identity of a natural person, legal entity or another type of identity such as, for example, a URL of a website.



Image from: <http://www.cert.fnmt.es/>

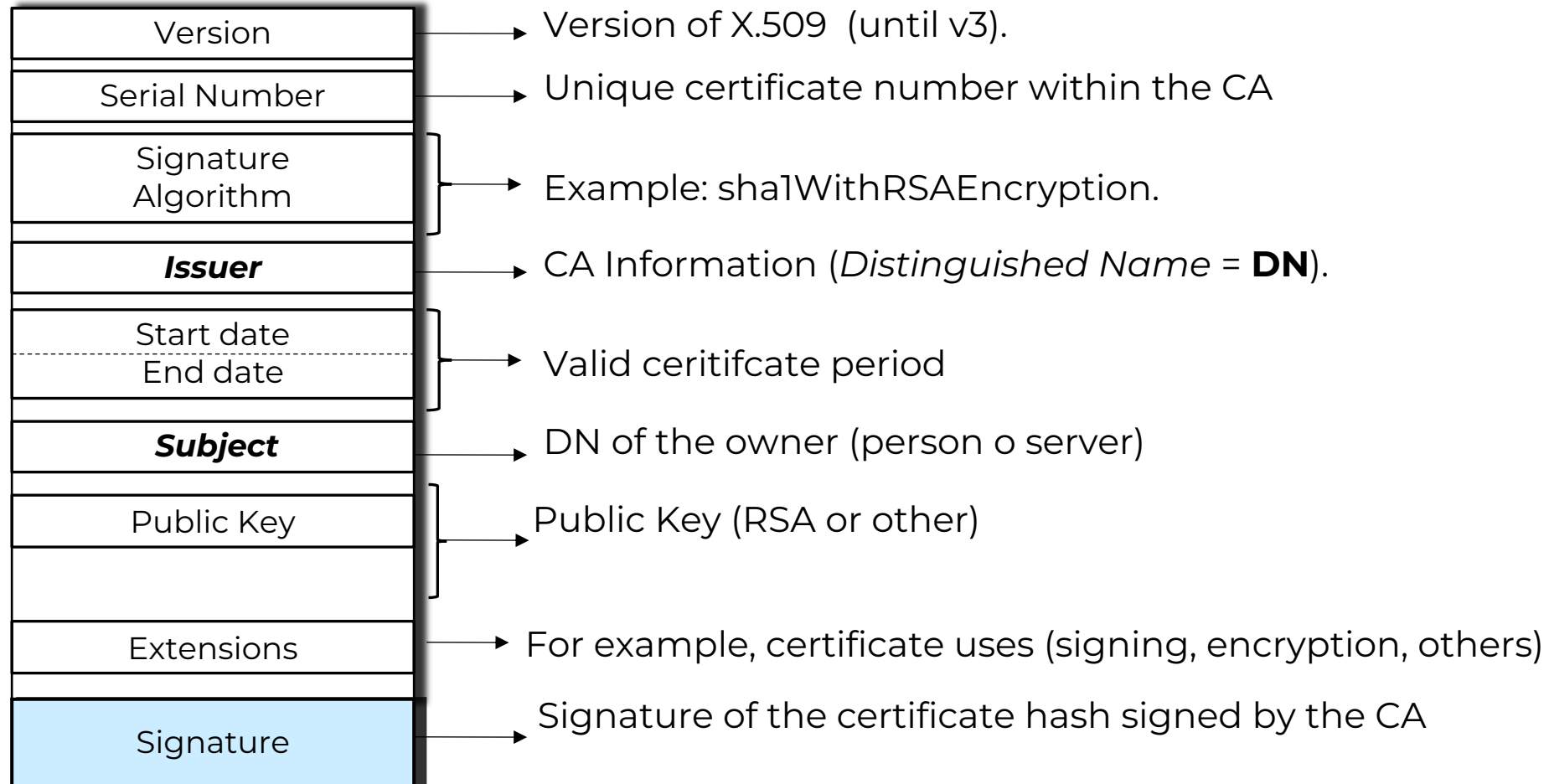
Types of Digital Certificates

- Personal certificate, which proves the identity of the holder.
- Certificate of belonging to a company, which, in addition to the identity of the holder, proves their link with the entity for which they work.
- Certificate of representative, which in addition to belonging to the company also accredits the powers of representation that the owner has over it.
- Certificate of legal entity, which identifies a company or society as such when carrying out procedures before administrations or institutions.
- Server certificate, used in Web servers that want to protect the exchange of information with users from third parties.
- Code signing certificate, to guarantee authorship and non-modification of the code of computer applications.

Digital certificates in software and hardware

- Software Certificates
 - Digital document that can be stored on a storage device
 - Examples
 - FNMT Certificates
 - App Signing Certificates
- Hardware Certificates
 - A certificate that is stored on a hardware device that is also responsible for performing identity verification and signature operations
 - Examples
 - Spanish National ID

Format of an X.509 digital certificate



Firefox Certificate Storage

General

Inicio

Buscar

Privacidad &
Seguridad

Cuenta Firefox

Certificados

Quando un servidor solicite su certificado personal

☐ Seleccionar uno automáticamente

☒ Preguntar cada vez

☒ Consultar a los servidores respondedores OCSP para confirmar la validez actual de los certificados

Ver certificados...

Dispositivos de seguridad...

Administrador de certificados

Sus certificados

Personas

Servidores

Autoridades

Tiene certificados guardados que identifican estas autoridades de certificación

Nombre del certificado	Dispositivo de seguridad
▼ AC Camerfirma S.A.	
Chambers of Commerce Root - 2008	Builtin Object Token
Global Chambersign Root - 2008	Builtin Object Token
Camerfirma AAPP II - 2014	Disp. software de seguridad
Camerfirma Corporate Server II - 2015	Disp. software de seguridad
▼ AC Camerfirma SA CIF A82743287	
Camerfirma Chambers of Commerce Root	Builtin Object Token
Camerfirma Global Chambersign Root	Builtin Object Token

Ver...

Editar confianza...

Importar...

Exportar...

Eliminar o dejar de

Chrome

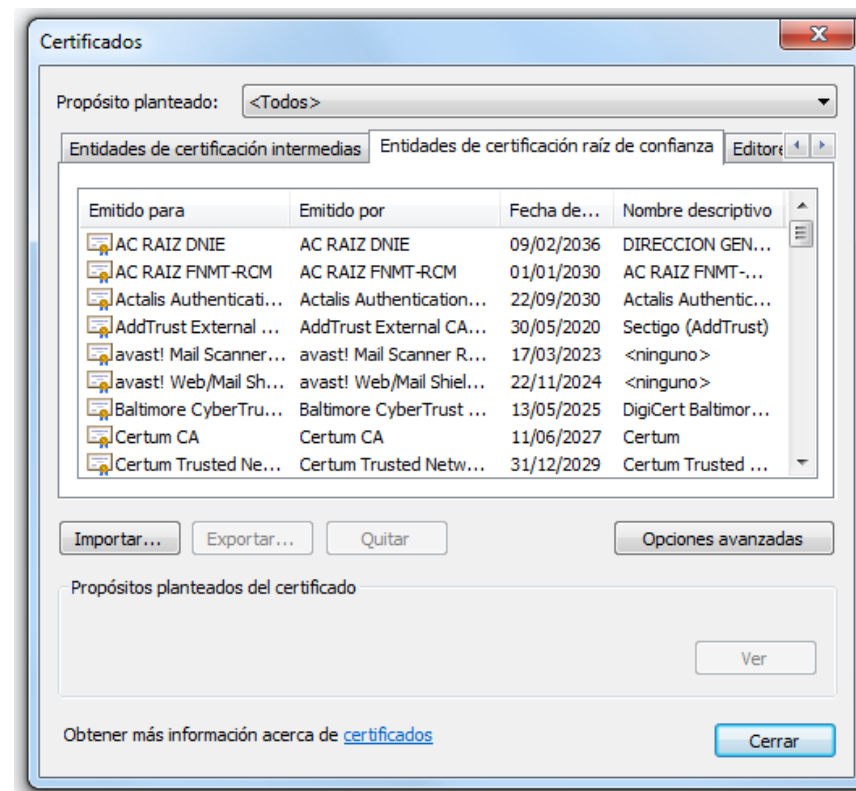
≡ Configuración

Configuración avanzada ▲

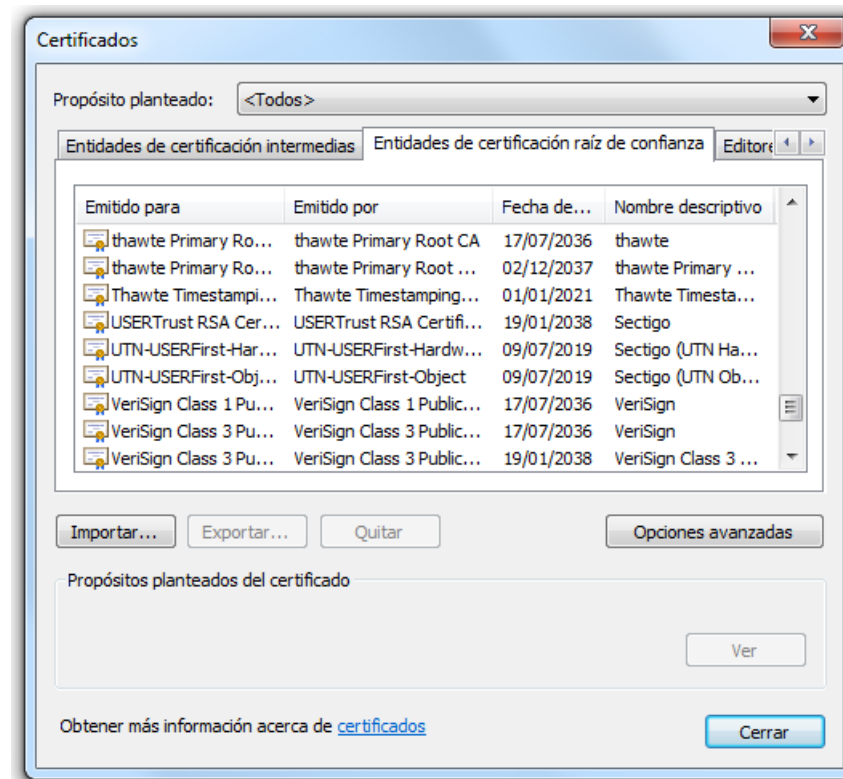
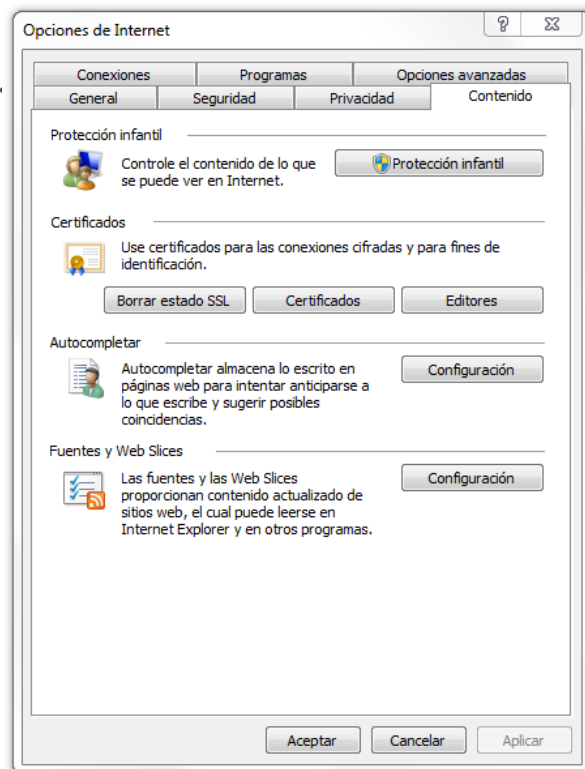
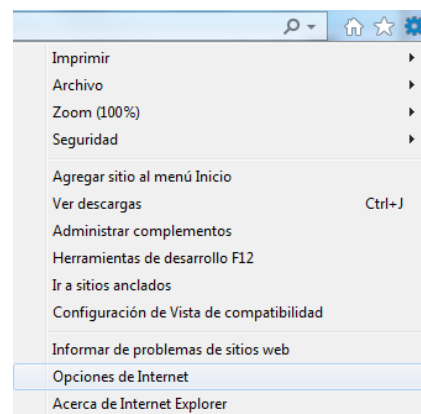
Privacidad y seguridad

Gestionar certificados

Administrar configuración y certificados HTTPS/SSL



Windows



“Secure” Browsing



Testing TLS

Test TLS

www.upm.es, 138.100.200.6:443

TLS Test Results from April 15 2024 15:54:41 UTC. Scan took 74 seconds.

Summary

Finding	Severity	Result
Secure Client Renegotiation	HIGH	VULNERABLE, DoS threat
OCSP Revoked	WARN	
TLS 1.2	OK	offered
TLS 1.3	OK	offered with final
Perfect Forward Secrecy	OK	offered
Common Name (CN)	OK	www.upm.es
Subject Alternative Name (SAN)	INFO	www.upm.es upm.es
CA Issuers	INFO	Sectigo ECC Organization Validation Secure Server CA (Sectigo Limited from GB)
Valid Not After	MEDIUM	2024-06-08 23:59

Preguntas

